

SimpleRisk Release Notes

Version: 20260820-001

This is the first generally available release since 20260519-001, and it carries everything from the two releases developed in between, which were never published on their own. Upgrading from 20260519-001 delivers all of it in one step: a new Home dashboard and redesigned Risk, Compliance, Governance and Incident dashboards; rebuilt Define Control Frameworks, Define Tests and Self-Assessments; an AI Capabilities Catalog and a Model Context Protocol server; and an extensive body of security hardening, including findings from an external penetration test.

If you are not currently running SimpleRisk, please download the application and follow the installation instructions for your preferred method.

If you are running a previous release, navigate to **Configure** → **Register & Upgrade** and click **Upgrade the Application**. This process upgrades both the application and the database to the latest release.

This release requires PHP 8.3 or newer. Check your PHP version and upgrade it first if needed; the application upgrade will not make an older PHP release work.

SimpleRisk Core

Security Issues

- Strengthened protection against forged cross-site actions across the application.
- Replaced the external database-backup command with a safer, self-contained backup process.
- Required authenticated POST requests for state-changing actions so they cannot be triggered by a simple link.
- Hardened output encoding of chart configuration values.
- Hardened encoding of redirect destinations.
- Hardened output encoding of playbook content.
- Tightened permission enforcement on tag-lookup requests.
- Hardened output encoding of the governance framework description.
- The management API key is now stored as a secure hash rather than as recoverable text.
- Enforced view-permission checks on compliance file downloads.
- Tightened permission enforcement on marking projects incomplete.
- Tightened permission enforcement on high-privilege fields in the risk-update API.
- Tightened permission enforcement on custom risk-score updates.
- Hardened encoding of administrator-configured colors used in reports and dashboards.
- Required an authenticated POST request for the risk reopen action.
- Restricted the Workflows HTTP Request action to an administrator-managed allow-list of approved destinations.
- Enforced per-module permission checks on internal data-table requests.
- Enforced team-separation checks on single-asset API lookups.
- Required the management API key to be sent as a request header rather than in the URL or form body.
- Enforced module permission checks on risk-report data-table requests.
- Scoped the user-manager API lookup behind a permission check.
- Tightened permission enforcement on risk tooltip requests.
- Tightened permission enforcement on risk review submissions.
- Validated the configured database-backup command path to prevent unsafe execution.
- Enforced permission checks across the remaining risk-management reporting requests.



- Restricted contributing-risks data-table requests to administrators.
- Tightened permission enforcement on review-date corrections.
- Tightened permission enforcement on incident-management configuration changes.
- Tightened permission enforcement on vulnerability-management updates.
- Enforced permission checks on incident-management report views.
- Enforced asset-access checks on the asset verify, discard, and delete actions.
- Scoped questionnaire answer pre-population to the same respondent to prevent cross-respondent disclosure.
- Hardened output encoding of the Jira link shown in the risk detail view.
- Tightened permission enforcement on assessment tag enumeration.
- Hardened output encoding in the risk filtering form action.
- Hardened output encoding of control names in the asset mapped-controls view.
- Hardened output encoding of chart axis titles and restricted chart selection options to an approved allow-list.
- Tightened permission enforcement on questionnaire result approval actions.
- Hardened spreadsheet exports of the Dynamic Risk Report against untrusted content that could be interpreted as a spreadsheet formula.
- Enforced a column-name allow-list and hardened encoding for custom display-settings columns.
- Restricted AI provider connections to an administrator-managed allow-list of approved destinations.
- Hardened workflow-driven updates to rich-text fields against stored malicious content.
- Hardened rich-text fields on controls, exceptions, tests, risks, mitigations, and reviews against stored malicious content.
- Required authenticated POST requests for the Upgrade Extra backup and upgrade actions.
- Hardened output encoding and tightened server-side permission checks on report downloads, addressing findings from an external penetration test.
- Hardened a mail-related rate limit.
- Tightened permission enforcement on compliance test results.
- Tightened permission enforcement on uploaded file downloads so a file cannot be reached from a module it does not belong to.
- Added missing permission checks to two API endpoints.
- Aligned the permission required by dashboard widget data requests with the permission required by the page that hosts them, and gave a business-unit risk exposure widget an explicit permission where it previously declared none.
- Increased the strength of stored multi-factor authentication secrets.



- Updated the single sign-on libraries to versions that address published security advisories.
- The sign-in form now accepts credentials only from a posted request body, keeping them out of places a request URL is routinely recorded.

New Functionality

- Added a Home dashboard as the default post-login landing page, with a Getting Started onboarding checklist and a redesigned, consistent set of Risk, Compliance, Governance, and Incident dashboards.
- Redesigning Define Control Frameworks as a framework list with its controls alongside, letting you record which controls apply to each framework and why, and generate a Statement of Applicability for any framework.
- Redesigning Define Tests: control tests can now recur on a fixed calendar cadence rather than only counting down from the last run, audits can require approval before they close with rejection back for rework, one test can be applied to many controls instead of being duplicated, and test history is viewable per test.
- Redesigning Self-Assessments to run against the Secure Controls Framework.
- Rebuilt the Connectivity Visualizer on an expanded entity graph that now includes exceptions, audits, vulnerabilities, and the risk and threat catalogues, with search, click-through exploration, and inline inspection of any item.
- Added an AI Capabilities Catalog so AI features can be enabled and discovered individually, and unified the AI settings into a single hub.
- Added an AI context graph and organization profile grounded in your GRC data, plus AI-suggested control tests with human review on the Define Tests page.
- Added a Model Context Protocol (MCP) server for external AI-assistant integration, including read-only discovery tools that let an assistant find controls needing attention, tests that are due, top risks, and the framework and control catalog — all gated by the same permissions that govern the underlying data.
- Ollama and other keyless local or self-hosted AI providers are now fully usable, and AI provider requests honor the configured web proxy.
- Emails that fail to send now raise a notification once delivery has been retried and given up, pointing to the Queue Monitor for per-message detail, with a configurable retention period on the Mail settings page.
- Customers with the Customization Extra can now replace the SimpleRisk logo and tagline with their own and publish a system use notice on the login screen, satisfying access-control requirements such as NIST 800-53 AC-8. An uploaded logo also appears in the top bar and on questionnaires sent to external respondents.
- Added an optional demonstration mode for operators running a shared, publicly accessible SimpleRisk instance. When enabled, SimpleRisk declines the self-service actions that would let one visitor disrupt the instance for everyone else. The setting is off by default and has no effect on a normal installation.



- Custom language files can now override only the strings you want and fall back to a base language for everything else, so they no longer need to carry the full string list on every upgrade.
- SimpleRisk now checks that an Extra is compatible with your installed release before installing it, and tells you plainly when the application needs to be upgraded first instead of leaving the install to fail. Extra and release information is now retrieved from updates.simplerisk.com; instances with restricted outbound access should make sure that host is reachable.

Performance / Availability

- Faster activation of the Custom Authentication Extra on new installs.
- Faster activation of the Import-Export Extra on new installs.
- Faster activation of the Encrypted Database Extra on new installs.
- Faster activation of the Artificial Intelligence Extra on new installs.
- Faster activation of the Vulnerability Management Extra on new installs.
- Faster activation of the Team-Based Separation Extra on new installs.
- Improved activation performance of the Jira Integration Extra.
- Improved activation performance of the Advanced Search Extra.
- Improved reliability of Workflows Extra activation and deactivation.
- Encrypted Database activation and deactivation no longer get stuck indefinitely if interrupted.

Aesthetics / User-Interface

- The Risk Assessment scheduling frequency now shows a clear disabled indicator instead of an ambiguous "0 days".
- Added confirmation feedback when clicking Save Draft on a questionnaire that has no unsaved changes.
- Added a collapsing sidebar and refreshed the navigation shell.
- Redesigned the login, password reset, and multi-factor screens.
- Control reference text written by AI is now attributed as such.

Bug Fix

- Fixed a fatal error when activating the Incident Management Extra after a permission key had been renamed.
- Fixed controls without a framework not appearing on the Define Tests page.
- Fixed controls without a framework not appearing on the Initiate Audits page.
- Fixed audit filter inputs unintentionally triggering column sorting.
- Fixed the Framework Name filter missing an "Unassigned" option.
- Fixed a server error on the Document Program page when a stakeholder table was missing.
- Preserved existing values when deactivating the Encrypted Database Extra to prevent silent data loss.
- Fixed screens that display tags, such as the Dynamic Risk Report, failing to load on PHP 8.4.
- Fixed a sent questionnaire still showing an editable form and a Save & Send button in the Risk Assessment Extra despite being non-editable.
- Fixed a crash during CSV import on PHP 8.1 when the file had no enclosure character.
- Fixed Shift+Enter inserting a block break instead of a line break in rich-text editor fields.
- Fixed the bypass-pending-risks checkbox not saving correctly on the questionnaire edit form.
- Fixed questionnaire draft save silently failing while still showing a success message for logged-in users.
- Fixed unknown API v2 routes returning HTTP 200 instead of HTTP 404.
- Fixed questionnaire draft save silently dropping file uploads.
- Fixed the questionnaire Draft button freezing the page when nothing had changed.
- Fixed removing a file from the questionnaire upload queue not being detected as a draft change.
- Fixed removed files reappearing after reloading the questionnaire fill page.
- Fixed a server error from the risk-average report API when given a non-numeric risk id.
- Fixed a server error from the send-questionnaire API when the id was missing.
- Fixed incomplete-questionnaire reminder emails firing indefinitely with no expiry once the response token had expired.
- Permission changes now take effect in the current session without requiring users to log out and back in.
- Fixed literal HTML entities appearing in the Dynamic Risk Report XLS export and other report and audit-trail exports.



- Fixed a spurious "could not decrypt" message on the Dynamic Risk Report for risks with empty fields.
- Fixed a fatal error that could occur when a newer Extra ran against an older core release.
- Fixed background document-processing issues that could cause excessive database growth, processing delays, and out-of-memory failures on large attachments, and ensured every file in a multi-file document is processed.
- Corrected the wording of the Encrypted Database activation error messages so they translate correctly across all supported languages.
- Fixed the Install buttons for the Workflows and Artificial Intelligence Extras on the registration page, which previously did nothing when clicked.
- Fixed several issues that could prevent SimpleRisk from upgrading, including a defect that stopped the one-click upgrade from running at all and issues affecting instances upgrading from much older releases. Instances running an older version of PHP are now upgraded as far as that PHP version supports rather than being refused entirely, a damaged Upgrade Extra can now repair itself, and the upgrade screen reports progress reliably regardless of web server configuration. Database backups taken during an upgrade no longer require external tools and now appear on the Backups page. Also corrects several database schema differences between upgraded and newly-installed instances.
- Duplicate instance identifiers are now detected and repaired during upgrade.
- Fixed questionnaire file attachments duplicating on save and being lost on completion.
- Fixed a regression that could stop auto-save and file management from working on questionnaires sent to external respondents.
- Saving a self-assessment response no longer discards the fields the request did not mention — a comment is preserved when only the answer is sent, and the answer is preserved when only the comment is sent.
- Fixed several defects in the Assessments questionnaire API: files attached to a specific question are now visible on the result, multi-line comments keep their line breaks, submitting no longer reports a false error on success, permission denials return the correct status code, an unknown questionnaire token is reported as not found, uploading or deleting a result file now requires the same permission as viewing the result, and saving a new template returns the created template's ID.
- Fixed an issue where requiring multi-factor authentication for all users could prevent users from signing in.
- Fixed an issue where a user required to change their password at first login was returned to the change-password page instead of continuing to sign in, when multi-factor authentication was also enabled for their account.
- Resolved an error that could prevent multi-factor enrollment on some database configurations.



- Fixed Import Controls and Import Risks rejecting valid rows, mishandling blank cells, and re-submitting on refresh.
- Test dates submitted through the API are now accepted in either date format, and an invalid date is reported — in your language, naming the field at fault — instead of being ignored.
- The Default Desired Maturity preference is now applied to new controls, instead of the dropdown ignoring it.
- Fixed AI features returning no result with newer thinking-enabled models, and AI-suggested control test generation producing no proposed tests.
- Fixed a bug that could cause a fresh installation to fail when the database schema contained tables with foreign keys defined out of dependency order.
- Fixed a bug where the extra-stylesheet loader never matched real stylesheet files, and hardened the in-page localization helper so pages degrade gracefully instead of erroring when a string is missing.
- Updated the data grid library used across risk, compliance, reporting, questionnaire, and assessment tables.
- Fixed the Document Program tables running off the right edge of the screen, which left the Actions column — and with it the edit and delete controls for every document — unreachable without scrolling to the bottom of the page and back.
- Fixed custom fields being lost when creating or editing a framework or control on Define Control Frameworks.
- Fixed the Preferences page reporting that your settings had been saved when nothing had changed, including a duplicated confirmation message for each asset valuation level. The page now saves only what you actually edited and reports accordingly. Also fixed a case where changing the default language at the same time as another preference discarded that other preference.
- Fixed missing single sign-on interface files — stylesheet, scripts, icons, and webfont — in the packaged release.
- Fixed a case where a failed Extra download could remove an already-working copy of that Extra.
- The built-in starter risk and threat catalogs are no longer created during an upgrade. These catalogs are now populated by the Secure Controls Framework import, which provides a more complete and better-maintained set. Existing catalog entries are left untouched, so this affects only instances upgrading from a version that had not yet received them.

Documentation

- The User and Administrator Guides have been rewritten to focus on the user experience rather than internal implementation details, with screenshots refreshed against the current interface.
- The Submitting a Risk, Recording an Incident, and Assessments articles now include a complete reference for every field on their forms, correcting several field-label and required-field inaccuracies.
- The VirtualBox and VMware appliance installation guides are now maintained alongside the rest of the documentation, and the risk import guide gains a full spreadsheet-preparation section.

Code Cleanup

- Removed unused build tooling files from the application directory.

Language Updates

- Refreshed translations across the supported languages.

SimpleRisk Extras

Risk Assessment Extra

- Added a Reopen action for rejected questionnaire results.
- Scheduling and notification fields can now be edited after a questionnaire has been sent.
- Added an API endpoint that returns a respondent's submitted questionnaire answers as structured JSON.
- Assessment invitation and result-share emails to external contacts are now delivered on instances using the Encrypted Database Extra.

Custom Authentication Extra

- Fixed SAML SSO asset and module URLs not resolving correctly.

Secure Controls Framework Extra

- Fixed an issue that prevented the Extra from installing or updating against the SCF 2026.2 content release.

Workflows Extra

- Fixed internal links breaking when SimpleRisk is installed in a subdirectory.

Vulnerability Management Extra

- Fixed configure forms not saving.

Customization Extra

- Custom field values now prefill correctly when you open an existing framework or control for editing on Define Control Frameworks.

Other Extra Updates

- The Statement of Applicability can be downloaded as an Excel workbook or PDF, and the PDF now carries a running header and page numbers on every page.